

Seven Seas A-13

Security Audit

July 24, 2024

Version 1.0.0

Table of Contents

- [Introduction](#)
- [Overall Assessment](#)
- [Specification](#)
- [Source Code](#)
- [Issue Descriptions and Recommendations](#)
- [Security Levels Reference](#)
- [Issue Details](#)
- [Disclaimer](#)

Introduction

This document includes the results of the security audit for Seven Seas's smart contract code as found in the section titled 'Source Code'. The security audit was performed by the Macro security team on periodically from July 15th to July 23rd 2024.

The purpose of this audit is to review the source code of certain Seven Seas Solidity contracts, and provide feedback on the design, architecture, and quality of the source code with an emphasis on validating the correctness and security of the software in its entirety.

Disclaimer: While Macro's review is comprehensive and has surfaced some changes that should be made to the source code, this audit should not solely be relied upon for security, as no single audit is guaranteed to catch all possible bugs.

Overall Assessment

The following is an aggregation of issues found by the Macro Audit team:

Severity	Count	Acknowledged	Won't Do	Addressed
Medium	1	-	-	1
Code Quality	1	-	-	1

Seven Seas was quick to respond to these issues.

Specification

Our understanding of the specification was based on the following sources:

- Discussions with the Seven Seas team.
- Available documentation in the repository.

Source Code

The following source code was reviewed during the audit:

- **Repository:** [boring-governance](#)
- **Commit Hash:** 97cac85c5c99b39dbd9310f0147f7867928aa4dd

Specifically, we audited the following contracts within this repository. Additionally to the scope of this audit, integration with VaultCraft vaults and their curve based gauge reward contracts was reviewed and found that existing ERC4626 and Curve decoders/santizers could be safely used.

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/CamelotDecoderAndSanitizer.sol	3737bc9618eb0d2629f7e20fcae033578858bef23bfab214469fcfe629b2932d
src/base/DecodersAndSanitizers/Protocols/MerkIDecoderAndSanitizer.sol	3b83d0d572cebdead00d0b5d780660dec59e1f2859bf5de6ab60cb303f303704
src/base/DecodersAndSanitizers/Protocols/CompoundV3DecoderAndSanitizer.sol	b59046a3f0772659bc4f9551d694034bb5a3e9db2006864cd90457fe654cec71

Note: This document contains an audit solely of the Solidity contracts listed above. Specifically, the audit pertains only to the contracts themselves, and does not pertain to any other programs or scripts, including deployment scripts.

Issue Descriptions and Recommendations

Click on an issue to jump to it, or scroll down to see them all.



Incorrect decoding of path



Misnamed Camelot position manager

Security Level Reference

We quantify issues in three parts:

1. The high/medium/low/spec-breaking **impact** of the issue:

- How bad things can get (for a vulnerability)
- The significance of an improvement (for a code quality issue)
- The amount of gas saved (for a gas optimization)

2. The high/medium/low **likelihood** of the issue:

- How likely is the issue to occur (for a vulnerability)

3. The overall critical/high/medium/low **severity** of the issue.

This third part – the severity level – is a summary of how much consideration the client should give to fixing the issue. We assign severity according to the table of guidelines below:

Severity	Description
(C-x) Critical	We recommend the client must fix the issue, no matter what, because not fixing would mean significant funds/assets WILL be lost.
(H-x) High	We recommend the client must address the issue, no matter what, because not fixing would be very bad, or some funds/assets will be lost, or the code's behavior is against the provided spec.
(M-x) Medium	We recommend the client to seriously consider fixing the issue, as the implications of not fixing the issue are severe enough to impact the project significantly, albeit not in an existential manner.
(L-x) Low	The risk is small, unlikely, or may not be relevant to the project in a meaningful way. Whether or not the project wants to develop a fix is up to the goals and needs of the project.
(Q-x) Code Quality	The issue identified does not pose any obvious risk, but fixing could improve overall code quality, on-chain composability, developer ergonomics, or even certain aspects of protocol design.
(I-x) Informational	Warnings and things to keep in mind when operating the protocol. No immediate action required.
(G-x) Gas Optimizations	The presented optimization suggestion would save an amount of gas significant enough, in our opinion, to be worth the development cost of implementing it.

Issue Details

M-1

Incorrect decoding of path

TOPIC

Protocol Design

STATUS

Fixed [↗](#)

IMPACT

Medium

LIKELIHOOD

Medium

In [CamelotDecoderAndSanitizer.sol](#)'s `exactInput()` function it sanitizes the inputs to swap on Camelot by interacting with its swap router:

```
function exactInput(DecoderCustomTypes.ExactInputParams calldata params)
    external
    pure
    virtual
    returns (bytes memory addressesFound)
{
    // Nothing to sanitize
    // Return addresses found
    // Determine how many addresses are in params.path.
    uint256 chunkSize = 23; // 3 bytes for uint24 fee, and 20 bytes for address
    uint256 pathLength = params.path.length;
    if (pathLength % chunkSize != 0) revert CamelotDecoderAndSanitizer__BadPathLength;
    uint256 pathAddressLength = 1 + (pathLength / chunkSize);
    uint256 pathIndex;
    for (uint256 i; i < pathAddressLength; ++i) {
        addressesFound = abi.encodePacked(addressesFound, params.path[pathIndex]);
        pathIndex += chunkSize;
    }
    addressesFound = abi.encodePacked(addressesFound, params.recipient);
}
```

Reference: [CamelotDecoderAndSanitizer.sol#L28-L47](#)

Camelot is similar to uniswapV3, with one key distinction, there aren't separate pools for pairs based on the fee/tick spacing. This means paths used to define swaps do not

require to specify a fee which would typically determine the pool used for the swap. So when sanitizing the path, the chunk size is 20, not 23, since only addresses are included in the path.

Remediations to Consider

Handle the path sanitization without handling for pool fees.

 Misnamed Camelot position manager

TOPIC	STATUS	QUALITY IMPACT
Code quality	Fixed 	Low

In [CamelotDecoderAndSanitizer.sol](#), the value `velodromeNonFungiblePositionManager` should be renamed to `camelotNonFungiblePositionManager` as that is the protocol being interacted with.

Disclaimer

Macro makes no warranties, either express, implied, statutory, or otherwise, with respect to the services or deliverables provided in this report, and Macro specifically disclaims all implied warranties of merchantability, fitness for a particular purpose, noninfringement and those arising from a course of dealing, usage or trade with respect thereto, and all such warranties are hereby excluded to the fullest extent permitted by law.

Macro will not be liable for any lost profits, business, contracts, revenue, goodwill, production, anticipated savings, loss of data, or costs of procurement of substitute goods or services or for any claim or demand by any other party. In no event will Macro be liable for consequential, incidental, special, indirect, or exemplary damages arising out of this agreement or any work statement, however caused and (to the fullest extent permitted by law) under any theory of liability (including negligence), even if Macro has been advised of the possibility of such damages.

The scope of this report and review is limited to a review of only the code presented by the Seven Seas team and only the source code Macro notes as being within the scope of Macro's review within this report. This report does not include an audit of the deployment scripts used to deploy the Solidity contracts in the repository corresponding to this audit. Specifically, for the avoidance of doubt, this report does not constitute investment advice, is not intended to be relied upon as investment advice, is not an endorsement of this project or team, and it is not a guarantee as to the absolute security of the project. In this report you may through hypertext or other computer links, gain access to websites operated by persons other than Macro. Such hyperlinks are provided for your reference and convenience only, and are the exclusive responsibility of such websites' owners. You agree that Macro is not responsible for the content or operation of such websites, and that Macro shall have no liability to your or any other person or entity for the use of third party websites. Macro assumes no responsibility for the use of third party software and shall have no liability whatsoever to any person or entity for the accuracy or completeness of any outcome generated by such software.